

Отчет по лабораторно-практической работе №5
учебной дисциплины

МДК. 03.01 Моделирование и анализ программного обеспечения

Тема: «Стандарты и спецификации в области информационной безопасности»

Выполнил:
студент 622 гр.

Нехорошев М. О.

Проверил:
преподаватель

Чернова Ю. С.

Цель: Ознакомиться с основными стандартами и спецификациями в области информационной безопасности, а также научить их применять эти знания для создания практического документа — политики безопасности для вымышленной компании.

1. Изучение стандарта: ISO/IEC 27001

ISO/IEC 27001 — международный стандарт, определяющий требования к системе управления информационной безопасностью (СУИБ). Он основан на подходе PDCA (Plan-Do-Check-Act) и включает:

- 1) Оценку рисков и выбор мер контроля.
- 2) Разработку политик и процедур для защиты информации.
- 3) Мониторинг и улучшение СУИБ.

Основные принципы ISO/IEC 27001:

- 1) Конфиденциальность — доступ к данным только у авторизованных лиц.
- 2) Целостность — защита от несанкционированного изменения.
- 3) Доступность — обеспечение доступа к данным, когда это необходимо.

Использование ISO/IEC 27001 поможет:

- 1) Систематизировать процессы защиты данных.
- 2) Соответствовать регуляторным требованиям (GDPR, законы о персональных данных).
- 3) Повысить доверие клиентов.

2. Оценка рисков и угроз

2.1 Потенциальные угрозы и уязвимости

Угроза	Уязвимость	Последствия
Фишинг и социальная инженерия	Низкая осведомленность сотрудников	Утечка учетных данных, доступ злоумышленников
Вредоносное ПО (вирусы, ransomware)	Устаревшее ПО, отсутствие EDR-решений	Шифрование/утечка данных, простой
Внутренние угрозы (сотрудники)	Слабый контроль доступа (RBAC не настроен)	Саботаж, кража данных
DDoS-атаки	Отсутствие защиты на сетевом уровне	Отказ сервисов, финансовые потери
Утечки через облачные сервисы	Неправильная настройка прав доступа	Компрометация клиентских данных

2.2 Влияние угроз:

- 1) Финансовые потери (штрафы, убытки из-за простоя).
- 2) Репутационный ущерб (потеря клиентов).
- 3) Юридические последствия (нарушение GDPR).

3. План управления рисками на основе ISO/IEC 27001

3.1 Оценка вероятности и воздействия угроз

Угроза	Вероятность (1-5)	Воздействие (1-5)	Уровень риска
Фишинг	4	4	Высокий
Вредоносное ПО	3	5	Критический
Внутренние угрозы	2	5	Высокий
DDoS	3	4	Высокий

3.2 Меры по минимизации рисков

Технические меры:

- 1) Внедрение SIEM-системы (Splunk, IBM QRadar) для мониторинга угроз.
- 2) Шифрование данных (TLS, PGP для передачи; AES-256 для хранения).
- 3) Многофакторная аутентификация (MFA) для всех критичных систем.
- 4) Регулярное обновление ПО и применение заплаток.

Организационные меры:

- 1) Обучение сотрудников (раз в квартал — тренинги по фишингу).
- 2) Политика контроля доступа (принцип наименьших привилегий).
- 3) Резервное копирование (3-2-1 rule: 3 копии, 2 типа носителей, 1 вне офиса).

3.3 Процедуры на случай инцидентов с данными

- 1) Обнаружение (мониторинг, оповещение SOC).
- 2) Сдерживание (изоляция зараженных систем).
- 3) Устранение (удаление угрозы, восстановление из бэкапа).
- 4) Анализ (разбор инцидента, улучшение защиты).
- 5) Уведомление регуляторов (если затронуты персональные данные — 72 часа по GDPR).